UNIVERSIDAD DE SAN BUENAVENTURA
Tecnología en Desarrollo de Software · VI semestre
Programación Avanzada y Aplicada

Informe de la matriz de riesgos

Privacidad, seguridad, uso responsable y riesgos técnicos

Proyecto final: **AsistenteIA**, asistente académico móvil con .NET MAUI y una API REST de IA

Autores: Jeferson Wilderman González Tenjo, María Alejandra Gómez y José Leandro Ocampo
Docente: Mg. Sandra Esperanza Sánchez Barragán
Fecha de ejecución: 16 de octubre de 2026
Versión evaluada: commit `6a15fc1`, interfaz rediseñada (integrada en `main`)

1. Introducción

Este informe presenta la matriz de riesgos de AsistenteIA exigida en la Fase 12 de la guía del proyecto ("Aplicar uso responsable de inteligencia artificial"). Identifica los riesgos de privacidad, seguridad, uso responsable y operación, evalúa su nivel antes y después de los controles, y enlaza cada control con el lugar del código donde está implementado y con la evidencia de las pruebas.

2. Objetivo

Argumentar las decisiones de seguridad, privacidad, ética y accesibilidad de la aplicación, mostrando que cada riesgo relevante tiene un control implementado y verificado, y cuál es el riesgo que permanece.

3. Alcance

- Los seis riesgos obligatorios de la guía (R1–R6).
- Tres riesgos operativos identificados en el diseño (R7–R9).
- Tres riesgos nuevos encontrados durante las pruebas del 16 de octubre de 2026 (R10–R12).

4. Metodología

Cada riesgo se evalúa con una escala de tres niveles para la probabilidad y el impacto. El nivel de riesgo es el producto de ambos valores. Se evalúa dos veces: el **riesgo inherente** (sin controles) y el **riesgo residual** (con los controles implementados y verificados en las pruebas).

Valor	Probabilidad	Impacto
3	Alta: ocurre con frecuencia en el uso normal	Alto: daño a la persona, a sus datos o a la entrega académica
2	Media: puede ocurrir en algunos casos	Medio: afecta el uso, pero se recupera
1	Baja: poco probable	Bajo: molestia menor

Nivel = P × I	Clasificación	Tratamiento
6 a 9	**Alto**	Requiere control obligatorio y seguimiento
3 a 4	**Medio**	Requiere control y revisión periódica
1 a 2	**Bajo**	Se acepta con controles básicos

5. Matriz de riesgos

#	Riesgo	P	I	Inherente	Control principal	Residual
R1	Respuesta incorrecta o inventada	Alta	Alto	**Alto (9)**	Prompt de sistema que pide indicar incertidumbre y no inventar fuentes.	**Alto (6)**
R2	Datos personales en el prompt	Media	Alto	**Alto (6)**	Avisos visibles en Consultar, Configuración e Inicio.	**Medio (4)**
R3	Exposición de credenciales	Media	Alto	**Alto (6)**	SecureStorage (DPAPI/Keystore), Entry IsPassword, clave enmascarada (••••1234), sin registros en consola, .gitignore, clave tapada en las evidencias.	**Medio (3)**
R4	Dependencia de un proveedor	Media	Medio	**Medio (4)**	Proveedor seleccionable (Google Gemini o Pollinations) con una clave por proveedor.	**Medio (4)**
R5	Contenido inapropiado	Baja	Medio	**Bajo (2)**	Propósito académico definido en el prompt de sistema y en Acerca de.	**Bajo (1)**
R6	Falta de autoría	Media	Medio	**Medio (4)**	Prompts conservados en el historial, commits descriptivos en Git y declaración de uso de IA (08-declaracion-uso-ia.md).	**Bajo (2)**
R7	Indisponibilidad de red o del servicio	Media	Medio	**Medio (4)**	Revisión de conectividad, mensajes por código HTTP, reintento automático ante 503/429, tiempo de espera configurable y cancelación.	**Bajo (2)**
R8	Dependencias vulnerables	Baja	Alto	**Medio (3)**	dotnet list package --vulnerable (S01) y --deprecated (S02) sin resultados.	**Bajo (2)**
R9	Pérdida del historial	Baja	Bajo	**Bajo (1)**	SQLite en FileSystem.AppDataDirectory, persistente entre reinicios (P09).	**Bajo (1)**
R10	Cierre inesperado de la aplicación (nuevo)	Media	Alto	**Alto (6)**	Control MarkdownView (una etiqueta por párrafo, sin saltos de línea en Spans).	**Bajo (2)**
R11	Límites de cuota del proveedor gratuito (nuevo)	Alta	Medio	**Alto (6)**	Mensaje claro con el texto del proveedor ("Error 429: demasiadas solicitudes o cuota agotada...").	**Medio (4)**
R12	Latencia alta del proveedor (nuevo)	Media	Medio	**Medio (4)**	Tiempo máximo configurable (1 a 120 s, recomendado 120 s).	**Bajo (2)**

Mapa de calor del riesgo inherente (sin controles)

Impacto ↓ / Probabilidad →	Baja (1)	Media (2)	Alta (3)
Alto (3)	**R8**	**R2, R3, R10**	**R1**
Medio (2)	**R5**	**R4, R6, R7, R12**	**R11**
Bajo (1)	**R9**		

Mapa de calor del riesgo residual (con controles)

Impacto ↓ / Probabilidad →	Baja (1)	Media (2)	Alta (3)
Alto (3)	**R3**		
Medio (2)	**R6, R8, R10**	**R2, R4, R11**	**R1**
Bajo (1)	**R5, R9**	**R7, R12**	

Con los controles, ningún riesgo de privacidad o seguridad queda en nivel alto. R1 (respuesta incorrecta) sigue siendo el mayor riesgo residual porque depende del modelo de IA y no de la aplicación: la app reduce su impacto con avisos y la marca de verificación, pero la responsabilidad final de contrastar la información es del estudiante.

6. Fichas de riesgo

R1. Respuesta incorrecta o inventada

Elemento	Descripción
Causa	El modelo de IA puede "alucinar" datos, fechas o fuentes.
Consecuencia	El estudiante aprende o entrega información falsa.
Riesgo inherente	Probabilidad Alta × impacto Alto = **Alto (9)**
Control implementado	Prompt de sistema que pide indicar incertidumbre y no inventar fuentes; aviso de verificación en cada respuesta y en el texto compartido; marca de "verificada" en el detalle; recomendación en Inicio.
Dónde está	`AiService.SystemPrompt, ChatPage.xaml, DetailViewModel.ToggleVerifiedAsync`
Riesgo residual	Probabilidad Alta × impacto Medio = **Alto (6)**

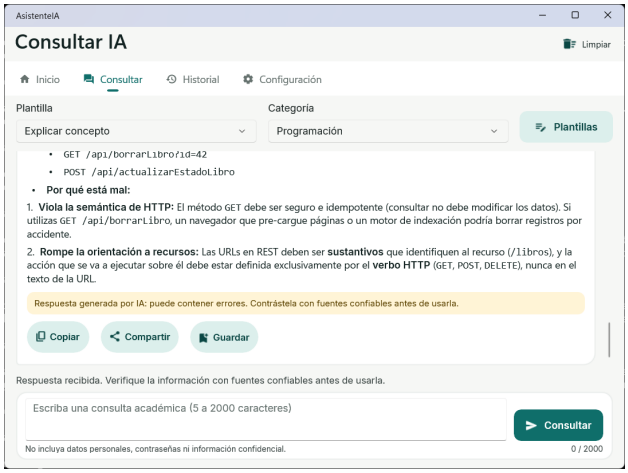


Figura 1. Aviso de verificación bajo cada respuesta.

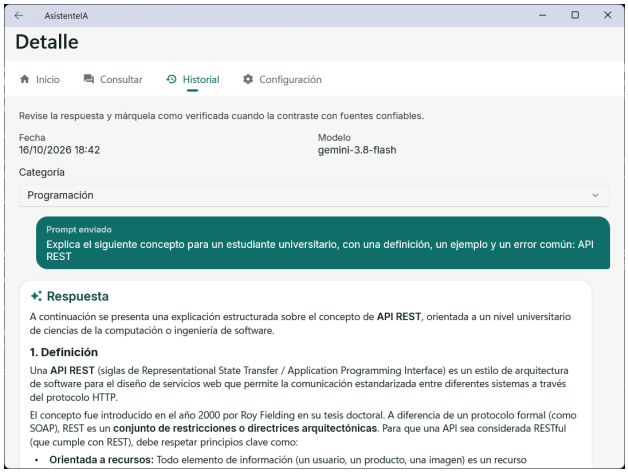


Figura 2. Respuesta marcada como verificada.

R2. Datos personales en el prompt

Elemento	Descripción
Causa	El usuario escribe datos propios o de terceros en la consulta.
Consecuencia	Los datos llegan al proveedor externo de IA.
Riesgo inherente	Probabilidad Media × impacto Alto = **Alto (6)**
Control implementado	Avisos visibles en Consultar, Configuración e Inicio; plantillas de propósito académico; historial solo en el dispositivo; las consultas solo se guardan si el usuario pulsa Guardar.
Dónde está	`ChatPage.xaml, SettingsPage.xaml, HomePage.xaml`
Riesgo residual	Probabilidad Media × impacto Medio = **Medio (4)**

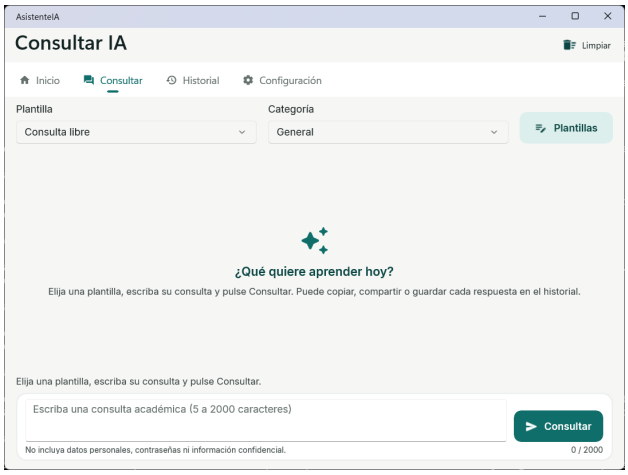


Figura 3. Aviso de privacidad bajo el cuadro de consulta.

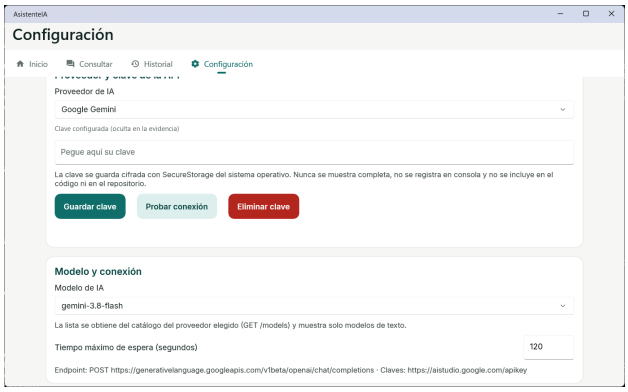


Figura 4. Aviso destacado en Configuración.

R3. Exposición de credenciales

Elemento	Descripción
Causa	La clave de la API queda en el código, el repositorio, una captura o la consola.
Consecuencia	Uso indebido de la clave y consumo de cuota o saldo por terceros.
Riesgo inherente	Probabilidad Media × impacto Alto = **Alto (6)**
Control implementado	SecureStorage (DPAPI/Keystore), Entry IsPassword, clave enmascarada (••••1234), sin registros en consola, .gitignore, clave tapada en las evidencias; verificado con git grep (S03).
Dónde está	`ApiKeyService, SettingsViewModel, .gitignore`
Riesgo residual	Probabilidad Baja × impacto Alto = **Medio (3)**

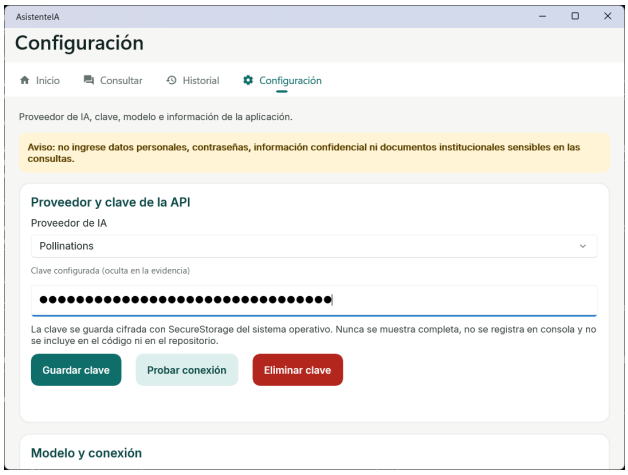


Figura 5. La clave se oculta al escribir.



Figura 6. Ninguna clave en el repositorio.

R4. Dependencia de un proveedor

Elemento	Descripción
Causa	El proveedor cambia modelos, precios, cuotas o autenticación, o deja de funcionar.
Consecuencia	La aplicación no puede responder consultas.
Riesgo inherente	Probabilidad Media × impacto Medio = **Medio (4)**

Elemento	Descripción
Control implementado	Proveedor seleccionable (Google Gemini o Pollinations) con una clave por proveedor; modelo configurable con lista dinámica (GET /models) y respaldo local; formato estándar compatible con OpenAI (AiProvider).
Dónde está	`SettingsService, AiService.GetModelsAsync, AiProvider`
Riesgo residual	Probabilidad Media × impacto Medio = **Medio (4)**

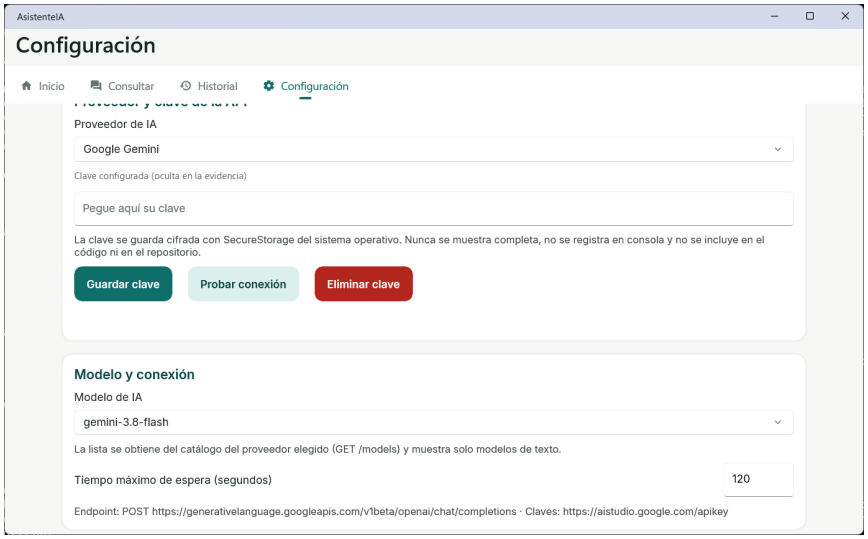


Figura 7. Selector de proveedor y modelo.

R5. Contenido inapropiado

Elemento	Descripción
Causa	El modelo genera contenido fuera del propósito académico.
Consecuencia	Uso indebido de la herramienta o respuestas ofensivas.
Riesgo inherente	Probabilidad Baja × impacto Medio = **Bajo (2)**
Control implementado	Propósito académico definido en el prompt de sistema y en Acerca de; la IA no se presenta como autoridad; los fallos se reportan al docente o al equipo.
Dónde está	`AiService, SettingsPage.xaml`
Riesgo residual	Probabilidad Baja × impacto Bajo = **Bajo (1)**

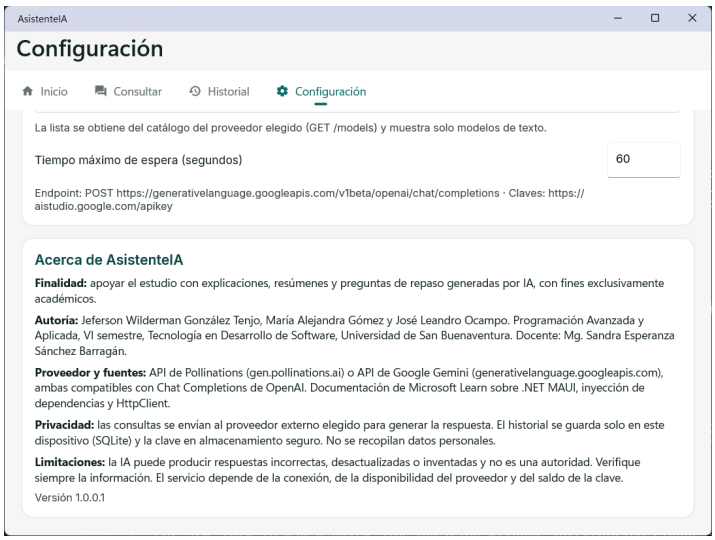


Figura 8. Sección Acerca de: finalidad y limitaciones.

R6. Falta de autoría

Elemento	Descripción
Causa	No queda registro de qué hizo el equipo y qué hizo la IA.
Consecuencia	El equipo no puede sustentar el producto.
Riesgo inherente	Probabilidad Media × impacto Medio = **Medio (4)**
Control implementado	Prompts conservados en el historial, commits descriptivos en Git y declaración de uso de IA (08-declaracion-uso-ia.md).
Dónde está	`ConversationRecord.Prompt, git log, docs/08-declaracion-uso-ia.md`
Riesgo residual	Probabilidad Baja × impacto Medio = **Bajo (2)**

Evidencia: historial de commits de la rama del proyecto y documento 08-declaracion-uso-ia.md, que registra las herramientas de IA usadas y qué hizo el equipo.

R7. Indisponibilidad de red o del servicio

Elemento	Descripción
Causa	Sin internet, red bloqueada o servicio caído.
Consecuencia	La consulta falla.
Riesgo inherente	Probabilidad Media × impacto Medio = **Medio (4)**
Control implementado	Revisión de conectividad, mensajes por código HTTP, reintento automático ante 503/429, tiempo de espera configurable y cancelación; la app no se cierra (P03, P05, P06).
Dónde está	`AiService.SendChatAsync, ChatViewModel`
Riesgo residual	Probabilidad Media × impacto Bajo = **Bajo (2)**

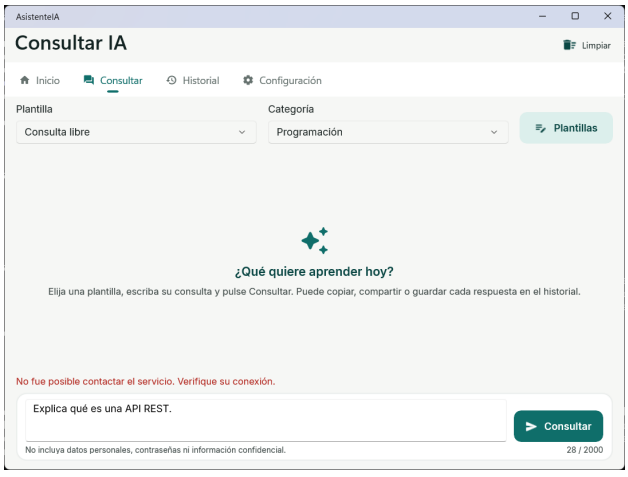


Figura 9. Mensaje sin conexión (P03).

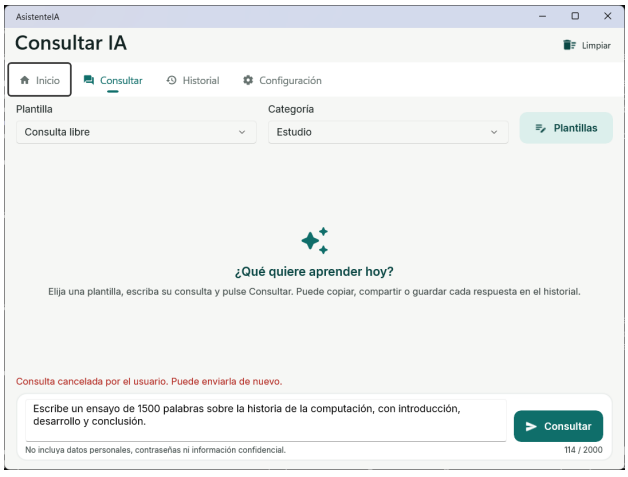


Figura 10. Consulta cancelada sin bloquear la interfaz (P06).

R8. Dependencias vulnerables

Elemento	Descripción
Causa	Un paquete NuGet o una librería nativa con vulnerabilidades conocidas.
Consecuencia	Puerta de entrada a ataques sobre el dispositivo o los datos.
Riesgo inherente	Probabilidad Baja × impacto Alto = **Medio (3)**
Control implementado	dotnet list package --vulnerable (S01) y --deprecated (S02) sin resultados; SQLite nativo fijado en versión parcheada.

Elemento	Descripción
Dónde está	`AsistenteIA.csproj`
Riesgo residual	Probabilidad Baja × impacto Medio = **Bajo (2)**

Seguridad · Paquetes NuGet con vulnerabilidades conocidas

```
$ dotnet list package --vulnerable --include-transitive

  Determinando los proyectos que se van a restaurar...
  Todos los proyectos están actualizados para la restauración.

Se han usado los orígenes siguientes:
   https://api.nuget.org/v3/index.json
   C:\Program Files (x86)\Microsoft SDKs\NuGetPackages\

El proyecto "AsistenteIA" especificado no tiene paquetes vulnerables en los orígenes actuales.

Resultado: APROBADO
```

Figura 11. Ningún paquete vulnerable.

R9. Pérdida del historial

Elemento	Descripción
Causa	Cierre o reinicio de la aplicación, o eliminación accidental.
Consecuencia	El estudiante pierde conversaciones guardadas.
Riesgo inherente	Probabilidad Baja × impacto Bajo = **Bajo (1)**
Control implementado	SQLite en FileSystem.AppDataDirectory, persistente entre reinicios (P09); eliminar pide confirmación (P08).
Dónde está	`DatabaseService`
Riesgo residual	Probabilidad Baja × impacto Bajo = **Bajo (1)**

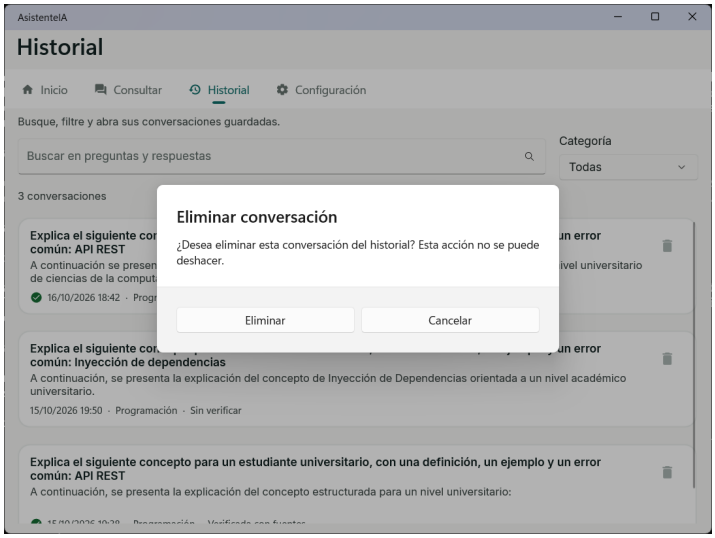


Figura 12. Confirmación antes de eliminar (P08).

R10. Cierre inesperado de la aplicación (nuevo)

Elemento	Descripción
Causa	Fallo de MAUI para Windows al dibujar respuestas largas con Spans de solo salto de línea (F18).
Consecuencia	Se pierde la conversación en curso y la confianza del usuario.
Riesgo inherente	Probabilidad Media × impacto Alto = **Alto (6)**

Elemento	Descripción
Control implementado	Control MarkdownView (una etiqueta por párrafo, sin saltos de línea en Spans); ScrollView en lugar de CollectionView; registro errores.log de excepciones no controladas; prueba de estrés con tres consultas largas sin cierres.
Dónde está	`Controls/MarkdownView.cs, Views/ChatPage.xaml, Platforms/Windows/App.xaml.cs`
Riesgo residual	Probabilidad Baja × impacto Medio = **Bajo (2)**

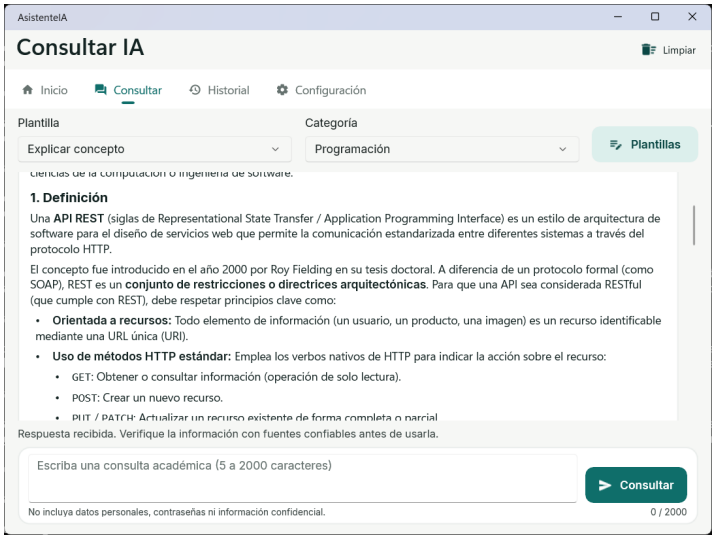


Figura 13. Respuesta larga mostrada sin cierres después de la corrección.

R11. Límites de cuota del proveedor gratuito (nuevo)

Elemento	Descripción
Causa	El plan gratuito de Gemini limita las solicitudes por minuto y por día.
Consecuencia	Error 429 y consultas rechazadas hasta que se renueva la cuota.
Riesgo inherente	Probabilidad Alta × impacto Medio = **Alto (6)**
Control implementado	Mensaje claro con el texto del proveedor ("Error 429: demasiadas solicitudes o cuota agotada..."); reintento automático; proveedor alternativo seleccionable; guía en el manual de usuario.
Dónde está	`AiService.CreateHttpErrorAsync, SettingsPage.xaml`
Riesgo residual	Probabilidad Media × impacto Medio = **Medio (4)**

Evidencia textual registrada en las pruebas: "Error 429: demasiadas solicitudes o cuota agotada. Espere un momento e intente de nuevo. (Proveedor: You exceeded your current quota...)". La aplicación siguió abierta y mostró el mensaje en rojo.

R12. Latencia alta del proveedor (nuevo)

Elemento	Descripción
Causa	El modelo gratuito tardó más de 60 s en respuestas largas durante las pruebas.
Consecuencia	Tiempo de espera agotado y la consulta debe repetirse.
Riesgo inherente	Probabilidad Media × impacto Medio = **Medio (4)**
Control implementado	Tiempo máximo configurable (1 a 120 s, recomendado 120 s); botón Cancelar; el texto vuelve al editor para reintentar.
Dónde está	`SettingsService.TimeoutSeconds, ChatViewModel.RestorePrompt`
Riesgo residual	Probabilidad Media × impacto Bajo = **Bajo (2)**

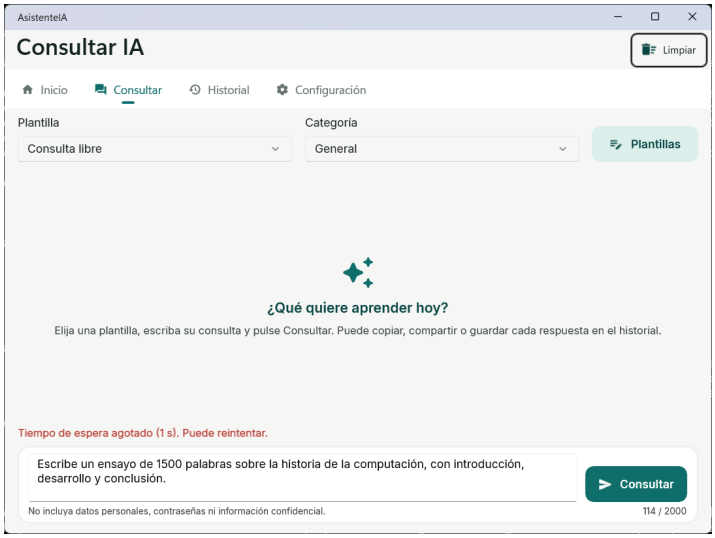


Figura 14. Tiempo agotado con el texto devuelto al editor.

7. Plan de seguimiento

Riesgo	Acción	Momento
R1	Repetir en la sustentación el ejemplo de marcar una respuesta como verificada y explicar por qué.	Sustentación
R3, R8	Ejecutar git grep de claves y dotnet list package --vulnerable / --deprecated.	Antes de cada entrega
R4, R11	Actualizar la clave de Pollinations (la guardada en el equipo de pruebas ya no es válida) para tener un proveedor alternativo funcionando.	Antes de la entrega
R10	Revisar errores.log después de las pruebas en Android y en la demostración.	Después de cada prueba
R12	Dejar el tiempo máximo en 120 s por defecto.	Antes de la entrega

8. Conclusiones

- Los seis riesgos que exige la guía tienen un control implementado, ubicado en el código y verificado con evidencia.
- Las pruebas automatizadas revelaron tres riesgos que no estaban en la matriz original (R10–R12). El más grave, el cierre inesperado de la aplicación, quedó corregido y verificado.
- El riesgo residual más alto es R1 (respuesta incorrecta de la IA). No se puede eliminar desde la aplicación, por lo que el diseño insiste en la verificación humana: avisos, marca de verificada y aviso al compartir.
- La dependencia de proveedores externos (R4, R11, R12) es el principal riesgo operativo para la demostración: conviene tener dos proveedores con clave válida y cuota disponible el día de la sustentación.